

Enumeracion Inicial

Solo para laboratorios autorizados. Sustituye variables, confirma versión y guarda salida.

Decisión rápida

1. Confirma alcance, identidad y conectividad.
2. Parte de una señal; no ejecutes toda la tabla.
3. Predice salida y prepara un control negativo.
4. Ejecuta la prueba menos intrusiva.
5. Registra evidencia y vuelve al módulo si falla.

Señales

- Un puerto abierto con una version concreta: tu primera pista para buscar CVEs.
- Hostnames en certificados TLS o en scripts de nmap: anadelos a /etc/hosts.
- Un puerto alto o raro responde con cabeceras HTTP.
- El nombre de servicio de Nmap no coincide con el banner o con el comportamiento.
- Puerto 53 (TCP/UDP) abierto en el objetivo.
- Un hostname en un certificado TLS o un email que revela el dominio interno a enumerar.
- nmap marca 445/tcp open microsoft-ds o el script smb saca el dominio.
- Un share con permiso READ que no sea IPC\$ (a menudo backups, transfer, dev).

Comandos y pruebas

Prueba	Objetivo/contexto	Evidencia esperada
<code>nmap -p- -Pn -n --min-rate 5000 \$IP -oN nmap/all_ports.txt</code>	Barrido de amplitud: los 65535 puertos sin scripts es rapido. -Pn evita que nmap descarte el host por no responder al ping (comun en labs).	Solo la lista de puertos open. Copia esos numeros para el segundo escaneo; ignora versiones aqui.
<code>nmap -sC -sV -Pn -p <PUERTOS> \$IP -oN nmap/services.txt</code>	Profundidad solo donde hace falta: version exacta (-sV, base de los CVEs) y scripts por defecto (-sC) que sacan datos gratis.	Versiones, banners, hostnames en certificados y hallazgos de scripts (smb anonimo, titulos web). Cada version -> searchsploit.
<code>nmap -sC -sV -Pn -p <PUERTO> \$IP</code>	Confirma que habla realmente el puerto y recoge scripts/banners utiles.	Servicio, producto, version y pistas como titulos HTTP o certificados.
<code>curl -i http://\$IP:<PUERTO>/</code>	Una comprobacion HTTP directa separa una aplicacion web real de una etiqueta de puerto equivocada.	Status, cabeceras y posiblemente framework o rutas a enumerar.
<code>dig axfr @\$IP dominio.local</code>	Intenta la transferencia de zona directamente. Es la prueba mas rentable: si el servidor la permite, obtienes todos los registros sin fuerza bruta.	Si funciona, una lista completa de registros A/CNAME/MX con nombres de host internos. 'Transfer failed' o REFUSED significa que esta bien configurado.
<code>nxc smb \$IP -u '' -p '' --shares</code>	Comprueba sesion nula y lista los shares de golpe. Es la prueba mas rentable en SMB: un share legible te ahorra toda la fase de explotacion.	Columna READ/WRITE por share. Un READ fuera de IPC\$ es saqueo directo. El encabezado tambien confirma nombre de equipo y dominio.
<code>nxc smb \$IP -u 'guest' -p '' --rid-brute</code>	Si hay acceso guest/nulo, itera los RID para sacar la lista de usuarios del dominio sin credenciales. Necesitas usuarios validos antes de rociar passwords.	Lineas SidTypeUser = usuarios reales. Extrae los nombres (sin las cuentas de maquina terminadas en \$) a users.txt para spraying y roasting.

Diagnóstico

Síntoma	Comprobar
Sin respuesta	ruta, DNS, puerto, listener y firewall
Rechazo	sintaxis, credenciales, permisos y versión
Salida distinta	control negativo, caché y estado
Resultado parcial	identidad efectiva y precondiciones

Cierre

- Guardar comando adaptado y salida.
- Anotar qué confirma y qué no.
- No persistir secretos en notas compartidas.
- Restaurar cambios del laboratorio.

Fuente operativa: conceptos de Fieldbook. Método: construcción de payloads.